Monthly Intelligence Dispatch

October 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview by Group-IB, an international company that specializes in the prevention of cyberthreats and the development of information security products. The objective of the Dispatch is to inform readers about the current cyberthreats, attacks by criminal groups, data leaks, and new malware. This report includes news of arrests and legal actions against members of hacker groups, as well as short-term forecasts and warnings that will help you take timely measures to protect yourself against cyberthreats. Group-IB's MTID is prepared for in-house use only and is not intended for wide distribution.

Key findings

- US security services succeeded in hacking and gaining control over the servers of a cybercriminal group REvil.
- A government-backed hacker group Nobelium, which gained a wide notoriety after their 2020 attack on SolarWinds, a US software publisher, committed more than 22,000 attacks on the clients of Microsoft in the months from July to October, 2021.
- In UAE criminals used a deepfake audio recording to imitate the voice of a large national company's CEO, beguiling bank managers into transferring $35 million to their account.
- A database with account data of more than 10 million users of Pin-Up.bet, an online casino and betting platform, was put up for sale on the darknet marketplace.
- Fraudsters have launched their own "Squid game": threat actors create phishing websites and distribute malware and game cards with unidentified QR-codes inspired by the wildly popular South Korean series.
- Group-IB identified more than 700 fake domain names of theatres, stand-up shows, restaurants, and cinemas used by fraudsters to steal money under the pretense of inviting their victims on a date.

Main story: REvil pushed offline

REvil

According to Reuters, the FBI, in conjunction with Cyber Command, and the US Secret Service managed to hack and gain control over the servers of a ransomware gang REvil. Up till recently, REvil was one of the most infamous ransomware operators. The list of their direct victims includes one of the key Apple partners, Quanta Computer, the world's largest meat supplier, JBS Foods, an IT colossus Acer, and an MSP-solutions provider Kaseya, whose business is based on managing the networks of thousands of smaller companies that don't have their own IT departments.

The REvils's lucky streak ended this July when their attack on Kaseya ended up in their whole infrastructure (websites and servers) going offline. Back then, Group-IB's experts suggested that this infrastructure fail might have been caused by
a special operation of the law enforcement authorities.

The Reuters' source has recently confirmed that after the REvil's attack on Kaseya, the FBI succeeded in hacking the gang's infrastructure, gaining control over some of their servers and obtaining a universal encryption key that allowed companies affected through Kaseya to restore their files without paying the ransom. Following that, REvil's members laid low for several months. When they attempted to bring their infrastructure back online, they switched on the internal systems that, as it turned out, at this point were already tracked by the law enforcers.

"The REvil ransomware group restored their infrastructure from the backup, assuming it had not been hacked," says Oleg Skulkin, deputy head of Digital Forensics Lab at Group-IB. "Ironically, this time ransomware slingers' favorite trick, backup compromise, was turned against them."

Key events: espionage, sabotage, leaks

Nobelium

A government-backed hacker group Nobelium, which gained a wide notoriety after their 2020 SolarWinds assult, committed more than 22,000 attacks on the clients of Microsoft in the months from July to October 2021. According to the company's official statement, threat actors tried to hack into the networks of more than 140 companies, with 14 of these attempts proving successful. The APTs mostly targeted other resellers and the provides of cloud service management services.

"Information about the attacks of the cybercriminal group Nobelium (aka Dark Halo) on the IT companies is nothing new to us," says Anastasia Tihonova, head of APT Research at Group-IB. "The IT sector is the key target for this group, since it allows them not only to hack the victim, a specific IT company, but to reach their multiple clients using supply chain attacks. That was demonstrated when the gang hacked a developing company SolarWinds, with their clients, including Microsoft, Cisco, and FireEye, suffering some damage as a result."

Already back then Group-IB experts assumed that the group has its own "area of expertise" and is not going to slow down its operations anytime soon. For instance, early this year a company called Mimecast also admitted having been attacked by Dark Halo; threat actors got email addresses and other contact information of the company's clients, as well as hashed account data. On top of that, the attackers gained access to the source-code repositories and downloaded them.

"As to to the incident attribution, there is no intelligible evidence that Russian cybercriminals stand behind the Dark Halo's activities," says a Group-IB expert. "No TTPs were presented proving that the Dark Halo's operations coincided with any other well-known APT group, the only possible exception being
a certain similarity between the Sunburst Backdoor software used by the Dark Halo and the Kazual RAT used by the Turla gang members. However, a similarity between two malwares cannot be regarded as an absolute guarantee of successful attribution."

A database with account data of more than 10 million users of Pin-Up.bet, an online casino and betting platform, was put up for sale on the darknet marketplace. Most stolen accounts are related to Russia even though the website was blocked in the country by the decision of the national Federal Tax Service.

Pin-Up.bet

According to Oleg Derov, head of the Group-IB Public Leaks Research Group, the database appeared on the market on October 5, containing full names, emails, birth dates, phone numbers, hashed passwords (bcrypt), gender data, home addresses, telephone numbers, bank account data (balance, currency). Either the records did not include payment information in the first place, or it has been erased, since the forum's rules do not allow selling or publishing this type of data. As stated by the source, the database contains records from late 2020, and its value is estimated at $10,000.

On the authority of a Group-IB expert, despite all the passwords in the database being stored in a hashed format and the data having been encrypted using a bcrypt algorithm, which is considered quite safe and resilient to the brute-force attacks, such leakages carry a significant threat to users. Having emails and phone numbers on their hands allows threat actors to convey massive malicious mailouts. In case such a mailout brings them any further user information, be it names, addresses, birth dates, account data etc., fraudsters can conduct targeted phishing or vishing attacks.

In total, in September 2021 Group-IB revealed about 120 published (though not for sale) databases. On average, these databases contain about 2.5 million lines of text, while only 7 out of 120 exceeded the size of the Pin-Up.bet leaked database. "This leakage has to be considered quite large, but it is not unprecedented neither by the international, nor by the Russian standards. For example, in 2012–2014 VKontakte and Rambler suffered a massive leak of user data. In those cases, each of the leaked databases contained account data of more than 90 million users," says Oleg Derov.

Key events: threats to bank customers

Fake Date

Group-IB identified more than 700 fake domain names of theatres, stand-up shows, restaurants, and cinemas used by fraudsters to obtain victims' money under the pretense of inviting them to a date. In the last three years, the Fake Date fraud scheme was picked up by some two dozen cybercriminal groups,
and one of them managed to pocket more than
RUB 18 million ($220,000) in one year alone.

The first cases of the Fake Date scheme usage in Russia were registered by the Group-IB experts as far back as 2018. The company came across some complaints from bank customers who were looking for a little romance and fell victim to the fraudsters after being asked on a date, which was supposed to take place in a private movie theatre room. The heyday of this internet fraud was registered during the COVID-19 pandemics.

This year fraudsters had a strong preference for theatres and stand-up shows as their "date spots" (60%). Fake restaurants, spa salons, hookah lounges are slightly less popular (35%), while movie theater rooms fell out of grace, plummeting to some 5%.

In some cases, the victim ends up paying three times: at first, they pay for their own ticket, then, "unexpectedly", they're asked to buy a ticket for their date, and finally, they get charged for the third time when requesting a refund.

It is worth noting that in the Fake Date scheme perpetrators adopted the hierarchy, technical base, operating model, and even slang of another popular internet fraud model "Mammoth" (in the fraudsters' vernacular, the word "mammoth" stands for victim). The work of frontline scammers (they're called "workers") is coordinated via Telegram, where dedicated chatbots offer ready-to-use phishing pages masquerading as the websites of theatres, cinemas restaurants, and hookah bars. These fake websites are equipped with all the necessary tools to generate tickets, obtain receipts, with all the detailed scripts in place. Advanced scammers can even buy prerecorded audio and video massages from girls who offer the victim to go on a date.

Key events: threats to bank customers

COVID_Fake

Starting from early September, Group-IB's Digital Risk Protection team has revealed 3,158 new offers to sell vaccination certificates. And it's 20 times more than in the summer of 2021! Most new offers were published in Telegram chats. Compared to the figures from last summer, there has been a change in the issuing time and price of the certificates. Back then, the price varied from RUB 3,000 to 30,000 (from $35 to $350), while the issuing of certificate took about three weeks. Now the certificate is worth from RUB 4,000 to 12,000, and sellers promise to deliver it in as little as three days.

The "product line" is expanding as well: sellers offer certificates not only for the Russian vaccines Sputnik V, EpiVacCorona, and CoviVac, but for the foreign Pfizer, CoronaVac, AstraZeneca, Moderna as well. The information about the sale of certificates is distributed via public Telegram chats, single-page websites, and social media pages.

On top of vaccination certificates, fraudsters offer negative and positive PCR and antibody tests, QR codes, and medical exemptions from vaccination. Group-IB's Digital Risk Protection experts would like to take this opportunity and remind you that forgery of official documents, their acquisition, as well as the use of knowingly false documents, including certificates of vaccination, refers to a criminal offence - Article 327 of the criminal code of the Russian Federation. Besides getting in trouble with the law, the buyers of false certificates may fall into the hands of fraudsters who steal money or payment information. One of the newly made fraudulent websites created on behalf of an imaginary institution, Federal Organization for Fighting CODID-19, offers to pay any Russian citizen RUB 9,879 ($120) from the national government as a form of welfare assistance. The website informs its visitors that the governmental institution has already transferred some RUB 19 billion ($232,000,000) providing financial help to 23 million people. To be eligible for this welfare payment, you only need a bank card; you should fill out a form with the recipient data, providing all your payment information including the CVV code (!).

Key events: fakeshops

Deepfakes

In UAE criminals used a deepfake audio recording to imitate the voice of a large national company's CEO, beguiling bank managers into transferring $35 million to their account. This case of criminals using deepfake audio is rare, but not unique. In 2019, the UK saw fraudsters steal as much as $220,000 from a utility company. Perpetrators masqueraded as the company's CEO, convincing an employee to transfer money to their account. "While in the case of deepfake videos people can still detect with a naked eye image artifacts produced by the neural network (for example, due to the so-called "uncanny valley effect"), it's much harder to tell a fake when it comes to audio recordings," says Vladimir Kalugin, head of special projects of the Digital Risk Protection Department at Group-IB.

"As a rule, fake audios are also created using neural networks, but this process is based on proven and mature technologies: after analyzing a voice sample, the network uses the results of this analysis to change (modulate) a synthetic profile. For instance, the sound analysis is used in the music industry for improving the voice part, while modulation is widely applied to transfer text into speech. We've all seen the examples of this technology at work in the form of voice assistants, such as Siri, Yandex's Alice, and many others. Besides, audio fakes are sent in the form of voice messages by messengers or phone, which makes sound distortions seem quite natural."

The Squid game

Fraudsters have launched their own "Squid game": threat actors create phishing websites and distribute malware and game cards with unidentified QR-codes inspired by the wildly popular South Korean series. For instance, ESET discovered a Google Play app that offered users to download The Squid Game-themed smartphone wallpapers while in fact installing a malware which signed up the victim for various services with monthly payment. In its turn, Group-IB found a phishing website designed after The Squid Game selling various Halloween merchandise.

"This autumn, CERT-GIB detected an explosive growth in the number of registered domain names related to the Netflix series "The Squid Game", says Yulia Zingan, CERT-GIB analyst. All in all, we identified 2145 domain names based on related keywords, and more than 95% of them were registered in September and October of this year, when the South Korean series was on the peak of its popularity. Of the total number of those "autumnal" domains, more than 90% were registered in the first half of October. The majority of these malicious websites are targeting foreign viewers, while the Russian audience attracts slightly more than 2%." Some 38% of the domains that were registered this autumn are used as marketplaces selling The Squid Game merchandise and work on the Shopify platform. Experts believe that users' payment information remains unthreatened when making purchases at the Shopify-based online stores, but there's no guarantee whatsoever that the buyers will receive the goods they paid for. According to Fakespot, about 21% of Shopify-based stores can in fact be fraudulent.

Key events: threats to bank customers

Fakeshops

The Group-IB Threat Intelligence analysts revealed three major fake shop networks, UniFake, JokerMantey, and SPAGETTI. Fraudsters make money on the unexperienced carders by creating and distributing phishing pages masquerading as “card shops”, online stores located in the dark web that sell compromised paying information.

For example, the largest of the discovered networks, SPAGETTI, contains more than 3,000 domain names, many of which are copies of the most popular carding websites in the dark web, including Joker’s Stash, BriansClub, Unicc, Ferum shop, ValidCC, and others. Since day one of their operation, the creators of this network received no less than 9,200 incoming transactions to various cryptocurrency wallets for the total amount of more than $1,200,000 (the major part of this sum was received in bitcoins and amounted to 23 BT as of October 12, 2021).

As a rule, fake shops are not created one at a time. To reach as many users (that is to say, potential buyers of the stolen bank cards) as possible, the fake shop operators advertise on underground forums and Telegram chats, beguiling the victims into following their links, and merge their sites into giant networks.

Arrests and sentences

DarkMarket

Europol conducted a special operation, known as **Dark HunTOR**, in seven European countries and the US. In total, police arrested 150 alleged suspects, seizing more than $26 million, 234 kg of drugs, and 45 firearms. These mass arrests stem from the earlier operation conducted by the special forces in January this year, when they took down the DarkMarket and arrested its administrators, gaining access to the infrastructure of the world's largest illegal marketplace of the dark web. According to the German police forces, the total transaction volume of Darkmarket went beyond $140 million. The market was mostly focused on selling drugs, but a part of its operation was related to cyber crimes.

REvil

Late September, Kyiv witnessed Ukrainian police forces detaining two hackers. According to the media reports, perpetrators are somehow related to the REvil gang. At this point, the law enforcement authorities were unable to reveal any details concerning this operations. The detained individuals can turn out to be either the partner program organizers or those who engaged in withdrawing the illegally obtained cash.

Forecasts and warnings

- Even though the REvil group went offline again, they followers remain active, and it will never go amiss to read Oleg Skulkin's blog where he describes in detail the tactics, techniques, and procedures used by REvil's partners. To give the cybersecurity professionals an opportunity to prepare for the potential attacks more efficiently, our expert REvil's partnes TTP with those used by MITRE ATT&CK.
- Threat actors from the Nobelium Group (aka dark Halo) are not going to curtail their efforts, since the IT sector is the key target of their activities and attacking IT companies allows them to reach not only the initial victims, but their multiple clients with supply chain attacks.
- Deepfake technologies are universally accessible, and because of that the number of fraud schemes that involve deepfakes will only be increasing in the near future. "There are lots of solutions catering both for the novices and professionals." Some services are designed to help users solve entirely legitimate tasks, for example, movie voice acting. Given that, they can easily be used to create audio deep fakes."
- The arrival of a new wave of COVID-19 pandemics with many countries going into lockdown will cause a rise in various fraudulent activities – phishing, vishing, and scamming.

If you would like to receive more detailed information about a specific incident, threat, or criminal group, please contact us.

We conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com